Ders 3 Genişletilmiş Notu: Ahlak, Etik ve Bilişim Suçları

Ders 3 Genişletilmiş Notu: Ahlak, Etik ve Bilişim Suçları

> Bu not, ders kaydının altyazısından hazırlanmış ayrıntılı ders notudur. Kısa tekrar için aynı dersin kısa notuna bakın.

İçindekiler

- 1. Dersin Planı ve Kaynaklar
- 2. Ahlak Nedir?
- 3. Ahlakı Besleyen Kaynaklar
- 4. Etik Nedir?
- 5. Ahlak, Etik ve Yasa
- 6. Bireysel Etik ve Meslek Etiği
- 7. Kurumsal Etik
- 8. Bilişim Etiği ve Etik Dışı Davranışın Sonuçları
- 9. Bilişim Suçlarına Giriş ve Sınıflandırma
- 10. Siber Suç, Etken ve Edilgen Saldırı, İç ve Dış Saldırı
- 11. İçeriden Saldırı 1: Salam Dilimi
- 12. İçeriden Saldırı 2: Dış Uzman
- 13. İçeriden Saldırı 3: Sanal Saatli Bomba
- 14. İçeriden Saldırı 4: Bilgi Hırsızlığı
- 15. Dışarıdan Saldırılar: Bilgi Çalma, Değiştirme ve Silme
- 16. Sistemin Çalışmasını Engelleme
- 17. İnternet Bankacılığı Soygunları ve Sosyal Mühendislik
- 18. Bilişim Yoluyla da İşlenen Suçlar
- 19. Özel Hayata Karşı Suçlar ve Kişisel Veri
- 20. Mal Varlığına Karşı Suçlar
- 21. Kötü Amaçlı Yazılımlar, Fidye Yazılımı ve Kritik Altyapılar

1. Dersin Planı ve Kaynaklar

Ders online yapıldı ve yaklaşık iki saat boyunca arasız sürdü. Hoca dersin iki ana başlığı olduğunu söyledi. Birincisi ahlak ve etik kavramları: önce ahlakın temel tanımları, sonra bireysel etik ve meslek etiği gibi kavramlarla ilişkisi, en sonda bilişim etiği. İkincisi bilişim suçları: saldırı türleri nelerdir, içeriden ve dışarıdan saldırı ile etken ve edilgen saldırı arasında ne fark vardır. Hoca bu suçları örnekleriyle, özellikle de etik ve hukuki boyutlarıyla tartışacaklarını söyledi.

Dersin temel kaynağı Eşref Adalı'nın *Bilişim Etiği ve Hukuku* adlı ders kitabıdır. Slaytlardaki içerik de temel olarak aynı yazarın sunumlarından alınarak hazırlanmıştır. Bunun dışında ilgili kanunlar ve maddeleri kullanıldı. ACM, IEEE ve Bilgisayar Mühendisleri Odası belgeleri ise özellikle sonraki derste, meslek etiği işlenirken kullanılacak. Hoca, bilişim etiği ve hukuku konusunda daha ayrıntılı okuma yapmak isteyenlerin slaytta adresi verilen bu kaynağa bakabileceğini söyledi.

2. Ahlak Nedir?

2.1 Tanım

Hocanın ilk tanımı şöyleydi: Kişilerin sosyal ortamlardaki ilişkilerini tanımlayan, düzenleyen ve bu ilişkileri irdeleyen kuralların bütününe ahlak denir. Bu ilişkileri düzenleyen oluşuma da ahlak kuralları ya da ahlak düzeni diyebiliriz.

Ahlak kurallarının birkaç temel özelliği var:

- **Çoğunlukla yazılı değildir.** Toplumların yaşamasıyla, zaman içinde oluşur.
- **Bir kısmı dini kaynaklardan gelir.** Yani din kitaplarından gelir.
- **Bir kısmı yasaya dönüştürülür.** Devletler ve yönetici hükümetler bazı ahlak kurallarını uyulması zorunlu yasalar haline getirir.

2.2 Yönlendirici Kurallar

Bireyler bir araya gelip bir toplum oluşturduğunda, birlikte yaşamı düzenli kılmak gerekir. Toplumun bu düzeni sağlamak için ürettiği kurallar topluluğuna **ahlakın yönlendirici kuralları** denir. Bu kuralları toplumun tamamı kabul etmez, ama büyük çoğunluğu doğru kabul eder ve uygular.

Hoca burada bir soru sordu: Uygulamayanlar ne olur? Ahlaksız olurlar. İnsan ahlaksız olmayı tercih edebilir mi? Edebilir. Hoca bunun örneklerini her gün gördüğümüzü söyledi ve ders tarihinden birkaç gün önce ortaya çıkan, hastanelerde bebek ölümlerine yol açan davranışları ahlak kurallarının hepsine temelden aykırı bir örnek olarak verdi.

Yönlendirici kurallar iki düzeyde olabilir:

- **Bireysel kurallar:** Bireyleri yönlendirir. Örnekler: başkalarına yardım et, hırsızlık yapma, adam öldürme, cana kıyma.
- **Toplumsal kurallar:** Toplumun genelini ilgilendirir. Örnekler: korsan kitap basmamak. Bilişim açısından ise lisanssız yazılım ve kaçak program kullanmamak.

2.3 Değerlendirme İlkeleri

Kuralların var olması yetmez, ne ölçüde uygulandıklarının da ölçülmesi gerekir. Bir toplum için geçerli olan yönlendirici kuralların ne derecede uygulandığını değerlendirmek için geliştirilen ilkelere **değerlendirme ilkeleri** denir. Bireylerin ve toplumun davranışları bu ilkelerle karşılaştırılır ve davranışın doğru mu yanlış mı olduğuna karar verilir.

Özetle ahlak iki bileşenden oluşur: bireysel ve toplumsal yönlendirici kurallar ile bu kuralların ne kadar yerine getirildiğini ölçen değerlendirme ilkeleri.

2.4 Farklı Bakış Açılarından Ahlak

Hoca ahlakın, hangi kaynaktan beslendiğine göre farklı biçimlerde tanımlanabileceğini söyledi:

- **Din açısından:** Ahlak, insanı kötülükten ya da günahtan koruma düzenidir.
- **Sosyal açıdan ve geçmiş kültürler açısından:** Ahlak, insan gelişimini sağlamak için yapılan eylemlerin amacıdır.
- **Kısa bir tanımla:** Ahlak, insanın zarar görmesini engellemek için konan kurallardır.

3. Ahlakı Besleyen Kaynaklar

3.1 Ahlak Kurallarının Özellikleri

Hoca önce ahlak kurallarının özelliklerini tekrar topladı. Ahlak kuralları genel olarak yazılı değildir. Toplumda yaşayan herkes bu kuralları bilir, ama herkesin bunlara uygun davrandığını söyleyemeyiz. Kurallar toplumun geneli tarafından benimsenmiştir. Ayrıca ahlak kuralları yalnızca bir kişi ya da bir grup için geçerli değildir, herkes için geçerlidir.

3.2 Altı Kaynak

Ahlakı şekillendiren kaynaklar şunlardır:

- **Dini kurallar:** Ahlakın oluşumunda doğrudan etkilidir. Dini kurallarla yönetilen toplumlarda çok baskındır. Dini kurallarla yönetilmeyen toplumlarda da ahlak dini geleneklerden beslenir. Yine yazılı değildir, ama yazılı kurallar gibi geçerlidir ve toplumda bu konuda bir uzlaşı vardır.
- **Temel değerler ve temel istekler:** İnsanların amaçladığı ya da özendiği hedeflerdir.
- **Düşünürlerin ve filozofların görüşleri.**
- **Toplumun kültürü.**
- **Etik kurallar.**
- **Yasalar:** Devleti yönetenlerin koyduğu kesin kurallardır.

3.3 Öznel ve Nesnel Değerler

Hoca temel değerleri ikiye ayırdı:

- **Öznel değerler:** İnsanın varlığından doğan, bizi insan yapan değerlerdir. Örnekler: mutlu olmak, sevmek, sevilmek, özgür olmak.
- **Nesnel değerler:** İnsanın özünden gelmez, sonradan kazanılır ve zaman içinde değişebilir. Örnekler: ev sahibi olmak, araba sahibi olmak, çok para sahibi olmak, zengin olmak.

Nesnel değerlerin değiştiğini göstermek için hoca ev sahibi olma örneğini verdi. Bugün bu isteğin en üst noktası "bir villam olsun" olabilir. Birkaç bin yıl önceki bir insana aynı soruyu sorsaydınız, ev kavramı olmadığı için "başımı sokabileceğim bir mağaram olsun" diyebilirdi. Yani nesnel değerler mağaradan villaya doğru evrilebilir.

Öznel değerler de toplum içinde sınırlanır. Özgür olmak insanın temel isteğidir, ama toplum olduğumuz anda başkalarının özgürlüğünü kısıtlamamak gerekir. Ben mutlu oluyorum diye başkaları mutsuz olmamalıdır. Toplum haline gelince bireysel hedefler biraz törpülenir. Hoca bunu "bir başkasının özgürlüğünün başladığı noktada sizin özgürlüğünüz biter" diye özetledi.

3.4 Kültür, Etik ve Yasalar

Kültür, toplumun yaşam şekliyle oluşur ve ahlak kurallarını etkiler. Bazı kültürlerde çok normal sayılan bir davranış, başka bir kültürde çok yanlış, hatta dine dayandırılarak günah sayılabilir. Etik kurallar da ahlakı oluşturur. Yasalar ise kesin hükümler getirir: Yasalaşmış bir ahlak kuralına uymazsanız bunun bir yaptırımı ve cezası olur.

3.5 İlkel Toplum Düşünce Deneyi

Hoca bu kaynakların nasıl işlediğini bir düşünce deneyiyle anlattı. Belgesellerde görülen, Güney Amerika'da ya da Afrika'da bir yerde, dış dünyadan tamamen soyutlanmış bir kabile düşünün. Sanayi ya da teknoloji yok. Bu toplumda din de olmasın, yönetici ya da hükümet yapısı da olmasın. Böyle bir toplumda bile, insanlar bir arada yaşadığı için temel değerler mutlaka olacaktır.

Bu toplumda biri mutlu olmak için ortalığı yıkıyor, ağaçları deviriyor, zarar veriyor olsun. Büyük olasılıkla diğer bireyler buna tepki gösterecek: "Mutlu oluyorsun ama her şeyi yıkıyorsun ve bizi zor duruma sokuyorsun." Belki dayak yiyecek, ama davranışı toplumda bir karşılık bulacak. Böylece toplum kendi ceza mekanizmasını geliştirir ve bireyin ahlak kuralını öğrenmesine ön ayak olur. Başka bireyler de "böyle bir şey yaparsam toplumsal tepki oluyor, demek ki bu doğru bir davranış değil" diyerek kuralı öğrenir ve içselleştirir. Zamanla kural çocuklara aktarılır ve kuşaktan kuşağa geçen bir ahlak kuralı halini alır.

Hoca ikinci örnek olarak canlı öldürmeyi verdi. Bu davranış, toplumda din ya da yönetici olsun olmasın, ahlak dışıdır. Ama her kaynak buna farklı bir ad verir:

- **Din:** Günah der, hem de en büyük günahlardan.
- **Kültür ve felsefe:** Günah demez, "çok yanlış bir davranış" der.
- **Yönetim (devlet):** "Cezalandırılması gereken bir hareket" der. Hafifletici sebepleri de tanımlayarak yasalar çıkarır.

Toplum, din, felsefe ve yönetim ahlakın oluşmasında etkili dört etkendir. Ama bu etkenler her konuda canlı öldürme örneğindeki gibi uzlaşmaz. Dinin kabul ettiğine yasa hayır diyebilir, felsefenin olur dediğine din hayır diyebilir. Bu tür çatışmalar sık yaşanır.

4. Etik Nedir?

4.1 Tanım

Hocanın en temel ve en basit tanımıyla etik, ahlak ilkelerinin düzenli halidir. Yani ahlak ilkelerinin düzenine etik denir. Etik, insanların karar vermesinde ve yaşamını hem bireysel olarak hem de toplum içinde sürdürmesinde doğrudan yol gösterici bir düzendir. Hem bireye hem topluma neyin doğru neyin yanlış olduğunu gösterir.

Etik de ahlak gibi şu sorularla ilgilenir:

- Doğru nedir, yanlış nedir?
- İyi yaşam nedir ve nasıl sağlanır?
- Bir insanın hakları ve sorumlulukları nelerdir?
- Nasıl ahlaklı karar verebilirim?

4.2 Etiğin Kaynakları

Etiği de ahlakta olduğu gibi toplumun kültürü, dini inançlar ve düşünürlerin görüşleri oluşturur. Hoca slayttaki listeyi okudu:

- Tanrı ve din
- İnsanın kendi vicdanı ve sezgileri
- Mantıkla oluşturulmuş ahlak
- Bir eylemin sonuçlarına yönelik fayda-maliyet analizi
- Mevcut iyi örnekler
- İnsanın her durumda iyi olma, en iyi insan olma isteği
- Politik güç

4.3 Bir Felsefe Alanı Olarak Etik

Etik ve ahlak birbirine çok yakın iki kavramdır. Ahlak ilkelerini sistematik bir halde düzenlediğinizde oluşan düzene etik denir. Etik aynı zamanda bir felsefe alanıdır: bireyin kendi içindeki, bireyler arasındaki ve bireylerle toplum arasındaki ilişkilerin tamamını belirleyen değerleri, kuralları ve töreleri araştırır. Hoca bunu “bire bir, bire n, n’e n” ilişkiler diye özetledi.

Hoca etiğin başka tanımlarını da verdi:

- İstenen, özenilen bir yaşamın nasıl olacağına dair araştırma ve bunun anlaşılması.
- Bütün etkinliklerde ve amaçlarda neyin yerine neyi koymamız gerektiğini belirleyen sistematik: Ne yapılır, ne yapılmaz? Ne istenebilir, ne istenemez? Neye sahip olunabilir, neye olunamaz?
- Toplumdaki davranışlardan doğru ve yanlış olarak kabul edilenlerin oluşturduğu küme.

4.4 Bilişim Etiğine İlk Bakış

Bilişimde de bir toplum vardır: bilişim alanında çalışanlar ve bilişim ortamlarını kullananlar. Yani hem üreten hem tüketen taraf. Bu bireyler arasındaki ve bireylerle toplum arasındaki ilişkileri belirleyen değerleri, kuralları ve töreleri araştıran felsefe alanına **bilişim etiği** denir. Normal etikten farkı, toplumun bilişim özelinde olmasıdır. Hoca bilişimi biraz daha sanal bir dünya gibi düşünebileceğimizi söyledi: İnsanlar fiziksel dünyada yaşıyor, bilişim ise ayrı bir etkileşim ortamı oluşturuyor.

5. Ahlak, Etik ve Yasa

Hoca, iç içe geçen kavramları bir özetle ayırdı.

Ahlak, toplumun çoğunluğu tarafından doğru kabul edilen kurallar, değerler ve ilkeler kümesidir. Bu kuralların neden ortaya çıktığı, nedenselliği araştırılmaz, kabul edilir. Ya töreye,

yani kültürel geçmişe, ya da dine dayandırılır. Bu yüzden her toplumun ahlak kuralları aynı değildir. Ahlak topluma özel, göreceli bir kavramdır. Ayrıca toplumun tamamının bildiği ama bazılarının uymadığı kurallardır.

Etik ise kuralların mantıksal yoldan oluşturulması için yapılan çalışmalardır. Hocaya göre bu yüzden toplumdan topluma değişmez, evrenseldir. Etik yalnızca sosyal ilişkilerde değil, özelleşmiş toplumlarda da geçerlidir: iş hayatında iş etiği, meslek hayatında meslek etiği, bilimsel çalışmalarda bilim etiği, bilişim alanında bilişim etiği.

Yasa, devletin yasama gücü tarafından belirli biçimlere uyularak düzenlenen kurallar bütünüdür. Yürürlüğe girdikten sonra o devletteki bütün vatandaşların uyması zorunludur. Uyulmadığında yaptırımı ve cezası vardır.

> **Hocanın vurgusu:** Ahlak görecelidir, etik evrenseldir, yasa zorlayıcıdır ve kesin kalıplar oluşturur.
>
> **Ders sonrası not:** "Etik evrenseldir" görüşü ders kaynağının yaklaşımıdır. Felsefede etiğin evrensel olup olmadığı (ahlaki görecelik tartışması) açık bir tartışma konusudur.

6. Bireysel Etik ve Meslek Etiği

6.1 Bireysel Etik

Toplumun temel yapı taşı birey olduğu için hoca etik türlerine bireysel etikten başladı. Bireysel etik, bir bireyin toplum içindeki davranışlarını belirler ve doğrudan kişinin kendi vicdanına dayanır.

Bireysel etiğe önem veren birinin kusur işlememeye, hata yapmamaya özen göstereceğine inanılır. Bireysel etik kişiyi kusursuz davranmaya yöneltir. Etik değerleri olan bir birey:

- Bir durumla karşılaştığında neyin doğru neyin yanlış olduğuna vicdanının sesine göre karar verir.
- Haksızlık olduğunda haksızlığa karşı çıkar.
- Hayatı boyunca yeni etik değerler öğrenebilir, edinebilir.
- Bir amaca ulaşırken yalnızca etik davranışlarda bulunur. Etik dışı yollarla amacına ulaşmaya çalışmaz.

Hoca ayrıca birey özgürleştikçe etik ölçütlerinin düzeyinin yükseldiğini söyledi. Ahlaktaki değerlendirme ilkelerine benzer şekilde, buradaki ölçütlerin, yani metriklerin seviyesi de yükselir.

6.2 Meslek Nedir?

Etik kavramının yaşandığı ortam bir meslekse, etik meslek etiği halini alır. Hoca mesleği şöyle tanımladı: Bir kişinin yaşamını sürdürmek için yaptığı, genellikle yoğun bir eğitim ve yoğun bir çalışma gerektiren sürecin sonunda kazanılan beceriler ve alınan unvanın adıdır.

Bu beceriyi kazanan kişinin becerisini insanlığın yararına kullanması ve mesleği düzgün şekilde icra etmesi beklenir. Etik olan budur. Hocanın örnekleri:

- Adalet alanında çalışan biri hakkaniyetli kararlar vermeli, bazı durumlardan etkilenmemeli, para karşılığında çıkar ilişkilerine girmemelidir.
- Hekim de aynı şekilde etik davranmalıdır.

6.3 Meslek Odaları

Her mesleğin kendine özgü değerleri ve etik ilkeleri vardır. Meslek değiştikçe etik ilkeler de değişebilir. Ama şu değişmez: Mesleğin bütün üyelerinin bu ilkelere uyması beklenir. Uymayanlara yaptırım uygulanabilir.

Bunun için meslek odaları kurulmuştur. Meslek odası, bir mesleğin örgütlenmesidir ve mesleğin etik kurallarını tanımlar. Bazı alanlarda bir işi yapabilmek için odaya üye olmak zorunludur. Üyelik sayesinde oda, etik kurallara uymayan üyeye yaptırım uygulayabilir. Hoca, mühendislik etiğine sonraki derste daha ayrıntılı bakacaklarını söyledi.

Meslek odaları sivil toplum örgütüdür. Koydukları etik kuralların ana hedefleri şunlardır:

- **Mesleğin toplumsal sorumluluğunu tanımlamak:** Mesleğin topluma karşı görevi ve sunduğu hizmetler için resmi bir tanım yapmak.
- **Tutarlı bir yol haritası çizmek:** Meslekle ilgili doğru ve yanlış eylemleri tanımlamak. "Şunlar etik davranışlardır, bunlar etik dışıdır" demek.
- **Üyeleri etik davranmaya yüreklendirmek:** Örneğin etik değerlere uygun çalışan üyeleri ödüllendirmek. Bu diğer üyeler için de teşvik olur: "Etik çalışırsam ödüllendiriliyorum, etik dışı olursam cezalandırılıyorum."
- **İlişkileri düzenlemek:** Meslek ekosisteminde işverenler, yöneticiler ve çalışanlar vardır. Bu üç taraf arasındaki ilişkilere dair kuralları koymak.

7. Kurumsal Etik

7.1 Tüzel Kişilik, Kurum ve Kuruluş

Ticari hayatta bir birey bile olsanız, kanun karşısında bir kurum ya da kuruluş, yani tüzel kişilik olursunuz. Hoca tüzel kelimesini "tüzükle oluşturulan", yani yasayla vücut bulan diye açıkladı. Tüzel kişilik, insan gibi canlı olmadığı halde yasa karşısında kişi gibi görülen ve bu nedenle cezalandırılabilen yapıdır.

Kurum ile kuruluş arasındaki fark şudur:

- **Kurum:** Devletin, halkın hizmet alması ve kamuyla ilgili işlemlerin yapılması için oluşturduğu resmi oluşumdur.
- **Kuruluş:** Bireylerin ya da ortaklıkların bir araya gelerek kurduğu, ticari hayatta yer alan ve esas amacı kurucularına ya da hissedarlarına kâr sağlamak olan işletmedir.

Kısacası kurumlar resmidir, kuruluşlar özeldir. Bireylerin, mesleklerin ve bilişim ortamının etiği olduğu gibi, kurum ve kuruluşların da uyması gereken kurallar vardır. Bunlara **kurumsal etik** denir.

Kurumsal etik, bireysel etik ve meslek etiğine göre çok daha yeni bir alandır. Hocanın gerekçesi: Sanayi Devrimi 1800'lerde yapıldı, büyük ölçekli işletmeler 1900'lerde oluştu. Ticaretteki rekabet nedeniyle kurumsal etiğe uymama da sık görülür. Hoca bu alanda çok fazla kötü örnek olduğunu söyledi.

7.2 Sadakat Kartı Örneği

Hocanın ilk örneği, dersten 22 yıl önce, 2002'de Türkiye'de başlayan bir sadakat kartı (loyalty card) uygulamasıydı. Bir mağaza grubu, "10 alışveriş yaparsan biri bedava", "alışverişlerinde yüzde 10 indirim", "belirli tutarı geçersen yüzde 15 indirim" gibi kampanyalar tanımladı. Bu kampanyalardan yararlanmak için sadakat kartı üyesi olmak gerekiyordu. Böylece müşterilerden çok sayıda kişisel veri ve alışveriş geçmişi toplandı. Hoca bunu veri madenciliği uygulamaları için hazır bir veri seti diye nitelendirdi. Sistemde 1,5 milyon müşteri bilgisi birikti. O dönemde KVKK yoktu.

Bir gün kartın sahibi olan grup, bütün müşteri bilgileriyle birlikte sistemi yabancı bir bankaya sattı. Banka da kendi adıyla sadakat kartının adını birleştirerek kartları kredi kartına dönüştürdü. Müşteriler bir anda yabancı bir bankanın müşterisi ve kredi kartı sahibi oldu. İsteyen iptal ettirebiliyordu.

Hocaya göre etik olmayan nokta şudur: 1,5 milyon kişinin kişisel verisi yabancı bir bankaya satılıyor ve verinin sahibi hiçbir şey yapamıyor. Kişi, alışveriş geçmişini karşılığında hiçbir şey almadan bir bankanın eline vermiş oluyor.

7.3 Ticari Yasakları Delmek

Savaşlar nedeniyle bazı ülkelere ticaret yasağı uygulanabilir. Bir kuruluş bu yasağa uymak istemeyip başka ülkeler üzerinden dolaylı satışla ticarete devam ederse, bu da etik bir davranış değildir. Hoca güncel bir örnek olarak İsrail'e uygulanan ticaret yasağını verdi. Hocaya göre bazı şirketler, sanki Filistin'le ticaret yapıyormuş gibi gösterip gemiyi yine aynı limana

göndererek ticarete devam ediyor. Yasak bir şekilde deliniyor ve bu kurumsal olarak etik bir davranış değil.

7.4 Dizel Emisyon Skandalı

Hocanın üçüncü örneği dünyaca bilinen büyük bir Alman otomobil markasıydı. Motorlar için Euro 3, 4, 5, 6 gibi emisyon sınırları vardır ve bunlar için belli testler yapılır. Şirket, motor kontrol yazılımını özel bir şekilde kodlamıştı. Yazılım, aracın bir test paterni işletip işletmediğini kontrol ediyordu. Emisyon testi yapıldığını algılarsa motor farklı karışımlarla çalışıyor ve zararlı gaz salımı çok az çıkıyordu. Test paterni yoksa motor daha performanslı çalışıyor, ama zararlı gazları söylenenden çok daha fazla salıyordu.

Yazılım ortaya çıkınca ABD bu araçları satamayacağını söyledi, büyük bir kriz oldu ve şirket milyarlarca dolar tazminat ödedi. Şirket sonrasında motor tasarımlarını tamamen değiştirmek zorunda kaldı. Hocaya göre bu olay dünyada dizel motorların azalmasında da etkili oldu.

> **Ders sonrası not:** Hoca olayın 2016'da ortaya çıktığını söyledi. Skandal büyük olasılıkla Eylül 2015'te ABD Çevre Koruma Ajansı'nın (EPA) açıklamasıyla ortaya çıktı ve şirket Volkswagen'di. Hoca ayrıca şirketin "ABD'de araba satmaya devam ettiğini" söyledi. Büyük olasılıkla Volkswagen skandaldan sonra ABD'de dizel otomobil satışını durdurdu.

7.5 Hisse Fiyatını Şişirmek

Borsada işlem gören bazı şirketler kendilerini kâğıt üstünde olduğundan daha değerli gösterip hisse fiyatını balon gibi yükseltir. Fiyat yükseldikçe insanlar "bundan kâr ederim" diyerek daha çok alır, fiyat daha da yükselir. Sonra elinde çoğunluk hisse olan taraf yüksek fiyattan satar. Ardından şirketin gerçekte o kadar değerli olmadığı ortaya çıkar ve hisse değeri bir anda düşer.

Hocanın sayısal örneği: Bir payı 50 liradan aldınız. Sonra payın olması gereken değerinin 10 lira olduğu ortaya çıktı. Aradaki fark, küçük yatırımcıları "silkeleyen" tarafın cebine gider. Bunu şirketin kendisi de yapabilir, borsada hacimli işlem yapan kötü niyetli tüccarlar da yapabilir.

7.6 Kamu Kurumlarında Etik Dışılık

Kurumsal etik yalnızca özel kuruluşlar için değil, kamu kurumları için de geçerlidir. Hocanın örneği 1999 depremiydi. Deprem sanayinin en yoğun olduğu bölgede olunca ekonomi çöktü ve "bir kereye mahsus" diye ek vergiler çıkarıldı. Ama bu vergiler kaldırılmadı ve hocaya göre bugün hâlâ toplanıyor. Vergi toplamak maliyenin işidir. Ama tek bir amaç için, bir felaket dolayısıyla süreli ya da bir kerelik diye çıkarılan bir verginin, zorluklar geçtikten sonra "buradan iyi para geliyor" diye toplanmaya devam etmesi etik bir davranış değildir.

7.7 Kurumların Sorumlulukları

Kurumlar toplum içinde yer aldıkları için hem topluma karşı hem de kendi çalışanlarına karşı etik sorumluluk taşır. Bu iki ilişkinin ikisi de kurumsal etik başlığı altında değerlendirilir.

8. Bilişim Etiği ve Etik Dışı Davranışın Sonuçları

8.1 Bilişim Etiğinin İki Yönü

1950'lerden itibaren bilgisayarlar hayatımıza girdikçe bilişim de toplumsal bir uzay haline geldi. Bu yüzden bir bilişim etiği oluşturmak gerekti. Hoca bilişim etiğini yine bilişim alanında çalışanlar ve bilişim ortamını kullananlar arasındaki, ayrıca bunlarla toplum arasındaki ilişkileri belirleyen değerleri, kuralları ve töreleri araştıran bir felsefe alanı olarak tanımladı.

Bilişim etiğinin iki yönü vardır:

- **Sistemin oluşturulması ve yaşatılması etiği:** Bilişim sistemi yapmanın etiği.
- **Var olan sistemlerin kullanımı etiği.**

Yani yapmak ve kullanmak bilişim etiğinin birbirinden farklı iki yönüdür. Her ikisinde de etik değerler ve kurallar vardır.

8.2 Etik Değerlere Uymamanın Sonuçları

Hoca, etik değerlere uymamanın sonuçlarını bireysel, kurumsal ve toplumsal düzeyde sıraladı.

- **Bireysel sonuçlar:**
  - Saygınlık kaybı.
  - Toplumdan dışlanma.
  - Mesleki etiğe uymazsanız işinizi kaybetme.
  - İnsan olarak benliğe zarar verme, kendine saygıyı yitirme.
  - Meslek ve meslek örgütüyle bağların zayıflaması.
  - İş arkadaşlarıyla ilişkilerin bozulması ve kişisel imajın zedelenmesi.
- **Kurumsal sonuçlar:**
  - Güvenilirliğin yitirilmesi ve kurumsal imajın zedelenmesi.
  - Satış ve kâr kaybı, zarar etme, iflasa gitme.
  - Müşteri kaybı.
  - İş birliklerinin ve iş ortaklıklarının zayıflaması.
  - Çalışanlarla ilişkilerin ve örgütsel bağların zayıflaması.
- **Toplumsal sonuçlar:**
  - Kural dışı ve yasa dışı davranışlarda artış.
  - Toplumda yozlaşma, çürüme.
  - Uluslararası alanda, başka ülkeler arasında dışlanma.

Hocaya göre en kötüsü ve en tehlikelisi toplumsal ölçekteki bozulmadır.

9. Bilişim Suçlarına Giriş ve Sınıflandırma

9.1 Neden Bilişim Suçlarını Bilmeliyiz?

Hoca ikinci başlığa, bilişim etiğinin neden oluştuğunu hatırlatarak geçti. Bilgisayarlar yeni bir yaşam uzayı ve yeni bir toplum oluşturdu. Toplumda ahlak kurallarına uymayanlar olduğu gibi, bilişim ortamında da etik davranmayanların ve suç işleyenlerin olması doğal ve beklenen bir sonuçtur.

Bilişim suçları internetten önce de vardı, ama internetle birlikte bu suçlarda bir patlama yaşandı. Bugüne kadar yaşanan bilişim suçlarını bilmek, bilişim etiği ve hukuku için faydalı girdiler sağlar. Böylece etik olanın, suç olanın, hukuka uygun ya da aykırı olanın ne olduğunu daha iyi ayırt edebiliriz.

9.2 Teknik Sınıflandırma

Teknik açıdan bilişim suçları ve dolandırıcılıklar şöyle sınıflandırılır:

- **Etkisine göre:** etken saldırı ve dolandırıcılıklar ile edilgen saldırı ve dolandırıcılıklar.
- **Yapılış şekline göre:** bilişim sistemine içeriden yapılan ve dışarıdan yapılan saldırılar.
- **Amacına göre.**

9.3 Yasal Sınıflandırma

Hukuki açıdan ise Avrupa Birliği'ne uyum sürecinde değiştirilen ve yeni oluşturulan yasalara göre farklı bir sınıflandırma vardır:

- 1. Daha önce de bilinen, başka ortamlarda işlenen, ama artık bilişim yoluyla da işlenen suçlar.
- 2. Özel hayata ve hayatın gizli alanına karşı işlenen suçlar.
- 3. Mal varlığına karşı işlenen suçlar.
- 4. Bilişim alanında işlenen suçlar.

Yani teknik sınıflandırma ile yasalardaki sınıflandırma birbirinden farklıdır.

10. Siber Suç, Etken ve Edilgen Saldırı, İç ve Dış Saldırı

10.1 Siber Suç

Hocanın tanımı: Bilgisayar bir suçun nesnesiyse ya da suç işlemek için bir araç veya ortam olarak kullanılıyorsa, işlenen suça **siber suç** denir. Etken ve edilgen saldırılar da birer siber suçtur.

10.2 Etken ve Edilgen Saldırı

Edilgen (pasif) saldırının amacı yalnızca bilgi almaktır: bilgileri okumak, bir bilgiye erişmek. Bu bilginin genellikle gizli bilgi olması gerekir, çünkü açık bilgiye zaten herkes erişebilir. Hoca bunu istihbarat faaliyeti diye nitelendirdi.

Etken (aktif) saldırının amacı ise bir şeyleri bozmak, değiştirmek ya da yok etmektir. Edilgen saldırıda olduğu gibi bilgiler okunur, ama bunun yanında:

- Veriler değiştirilebilir.
- Veriler silinebilir.
- Sistemin çalışması durdurulabilir veya bozulabilir.
- Sistemin kaynaklarına zarar verilebilir.

Hoca “etken” kelimesinin, bir şeyin bir şeye etki etmesi anlamına geldiğini söyledi. Etkilenen şey veri, sistemin çalışması ya da sistemin fiziksel kendisi olabilir.

10.3 İç Saldırılar

İç saldırılar, çalışanların kendi kuruluşlarına karşı yaptıkları dolandırıcılıklardır. Amaç kişisel kazançtır, yani işin sonunda iş maddiyata dayanır. Hocanın örnekleri:

- Bir ödeme sistemini değiştirerek ya da üzerinde işlem yaparak kazanç sağlamak.
- Bir tedarik sisteminde işlem yaparak bir malın sahibi olmak.
- Seyahat ve yolluk sistemlerinde değişiklik yaparak ek ödeme almak.
- Çalışan yönetimi sisteminde dolandırıcılık yaparak daha fazla izin almak.
- Ödeme belgelerine ulaşarak kişisel kazanç sağlamak.
- Kuruluşun özel varlıklarını ve bilgilerini kullanarak kişisel kazanç sağlamak.

10.4 Dış Saldırılar

Dış saldırıları bir kişi, bir takım ya da başka bir kurum veya kuruluş yapar. Amaçları şunlardır: saldırılan tarafın bilgilerini okumak, verilerini değiştirmek veya silmek, çalışmasını aksatmak, kaynaklarına zarar vermek, işlemlerini engellemek ve bunları yaparak finansal kazanç sağlamak.

11. İçeriden Saldırı 1: Salam Dilimi

Parasal işlemlerin çok yoğun olduğu bankacılık, perakende ve hizmet sektörlerinde içeriden yapılan saldırılarla sık karşılaşılır. Hoca dört çeşit iç saldırı anlattı: salam dilimi, dış uzman, sanal saatli bomba ve bilgi hırsızlığı. Dış uzman, dışarıdan biri olduğu halde içeriden saldırı yaptığı için bu gruptadır.

11.1 Tanım

Salam dilimi (salami slicing) adı literatürde gerçekten böyle geçer. Hoca, ilgili makalede saldırı salam dilimleme örneğiyle açıklandığı için bu adı aldığını söyledi.

Faiz hesabı yapan ya da kiralık aracın ücretini gün ve kullanım miktarına göre hesaplayan yazılımlar düşünün. Bu tür hesaplama yazılımlarına küçük eklemeler ya da değişiklikler yapılarak çok küçük miktarlarda paralar soyulur. Miktarlar ince salam dilimleri gibi küçük olduğu için bu ad verilir.

11.2 Banka Örneği

Olay ABD'de bir bankada geçiyor. Finansal hesaplamalarda virgülden sonra iki basamak kullanılır, çünkü 100 cent 1 dolar, 100 kuruş 1 lira eder. Ama yıllık faiz oranını aylık ya da günlük faize çevirdiğinizde virgülden sonra daha fazla basamak, yani yarım centler oluşur. Bunlar yuvarlanır. Hocanın örneği:

- $0{,}113 \to 0{,}11$ (üçüncü basamak 0 ile 4 arasında olduğu için aşağı yuvarlanır)
- $0{,}115 \to 0{,}12$ (üçüncü basamak 5 ile 9 arasında olduğu için yukarı yuvarlanır)

Programcı, faiz hesabını yapan yazılımda "5'in altını aşağı, 5 ve üstünü yukarı yuvarla" demek yerine hepsini aşağı yuvarlatıyor. Yukarı yuvarlanması gereken farkları, yani yarım centleri, özel bir hesaba aktarıyor. Tek bir hesapta yarım cent kimsenin gözüne batmıyor. Hoca bunun her hesapta da olmadığını, olasılık olarak yuvarlama gereken hesapların yarısında yukarı yuvarlama gerektiğini ekledi.

Hoca burada bir hesap yaptı: Bin hesapta yarım cent kaç dolar eder? Önce "500 dolar mı, 50 dolar mı?" diye düşündü ve 50 dolar dedi. Günde bin işlem yapılırsa günde 50 dolar, 30 günde 1500 dolar olur dedi.

> **Ders sonrası not:** Hesap hatalı. Bin işlemde yarım cent $1000 \times 0{,}5 = 500$ cent eder. 100 cent 1 dolar olduğu için bu $500/100 = 5$ dolardır. 30 günde $5 \times 30 = 150$ dolar eder, 1500 dolar değil. Gerçek vakalarda kazancın büyük olmasının nedeni işlem sayısının çok daha yüksek olmasıdır.

Hoca daha büyük hacimli bir bankada kazancın çok daha fazla olabileceğini söyledi. Hilenin ortaya çıkarılması çok zordu. Hocanın anlatımına göre çok dikkatli bir müşteri "benim hesabıma göre bir cent yukarı olması lazımdı, neden aşağı yuvarlandı?" diye şikayet etti. Yapılan inceleme sonucunda programcının milyonlarca dolar götürdüğü fark edildi.

Hukuki açıdan: Programcı müşteriden ve bankadan doğrudan para, yani yarım centleri çalmıştır. Hukuken tamamen suçludur.

Etik açıdan: Programcı kuruluşun etik kurallarını çiğnemiş, hesaplarda hakkaniyetli davranılmamasına yol açmıştır. Bunun sonucunda banka da saygınlık kaybeder. Birçok müşteri "ben bu bankayla çalışmıyorum" diyerek parasını çekebilir. Banka hem müşteri hem saygınlık kaybeder.

11.3 Araç Kiralama Örneği

İkinci örnek yine ABD'de bir araç kiralama şirketinde geçiyor. Aracın deposu gerçekte 50 litre. Yazılımcı sistemde depo hacmini parametrik olarak 55 ya da 60 litre tanımlıyor.

Araç kiralamada yakıt politikaları vardır. Örneğin "dolu teslim ettim, dolu alırım" politikası. Hocanın sayısal örneği:

- **Verilen:** Gerçek depo 50 litre. Sistemde tanımlı depo 60 litre. Araç dolu teslim edildi. Müşteri aracı yarım depoyla getirdi.
- **Gerçekte eksik yakıt:** $50 - 25 = 25$ litre.
- **Sistemin hesapladığı eksik yakıt:** Araçta kalan 25 litre, sistemdeki 60 litrelik depoya göre değerlendiriliyor: $60 - 25 = 35$ litre (ara adım eklendi).
- **Sonuç:** Müşteriden 25 yerine 35 litrenin parası alınıyor. Aradaki $35 - 25 = 10$ litrelik fark özel bir hesaba aktarılıyor.

Hoca, ABD'de benzin ucuz olduğu için bu farkın pek fark edilmediğini söyledi. Hile yine ancak dikkatli bir müşteri "bu araç 50 litre depolu olmalı, ben nasıl 60 litre üzerinden ödüyorum?" diye şikayet edince ortaya çıktı.

Hukuki açıdan: Bu da doğrudan para çalmaktır. Tanımlamayı yapan programcı suçludur.

Etik açıdan: Yazılımcı kuruluşun etik kurallarını çiğnemiştir. Kuruluş müşteri ve saygınlık kaybeder. Kurumsal etik devreye girer ve kuruluş çalışan hakkında gerekeni yapar.

11.4 Çözüm

Bu tür eylemlerin fark edilmesi çok zordur. Çözüm, yazılım dünyasında yazılım güvenliği kontrol birimlerinin kurulması ve kod gözden geçirmelerinin (code review) düzgün yapılmasıdır. Böylece faiz hesabında ya da yakıt ücretinde "tırtıklama" yapılması engellenir.

> **Hocanın vurgusu:** Yazılım güvenliği için kontrol birimlerinin oluşturulması ve kod gözden geçirmelerinin düzgün yapılması çok önemlidir.

12. İçeriden Saldırı 2: Dış Uzman

12.1 Saldırı Nasıl Olur?

Kurumlar cihazların bakım ve güncellemesi gibi işler için genellikle kendi içlerinde sürekli çalışan barındırmaz, dışarıdan hizmet alır. Bir dış uzman gelir ve bilgisayarların, özellikle sunucuların bakımını yapar: güncellemeleri yükler, gerekiyorsa parça ya da kablo değiştirir.

Dış uzmanın sistem üzerinde işlem yapabilmesi için ona bir kullanıcı tanımlanması, en basitinden bir kullanıcı adı ve parola verilmesi gerekir. Uzman işletim sistemi güncellemesi gibi sistem düzeyinde işler yaptığı için bu hesaplar genellikle en üst düzeyde, root seviyesinde yetkilidir.

Bazen bu hesaplar iş bittikten sonra unutulur, devre dışı bırakılmaz ya da yetkileri kısıtlanmaz. Bu durumda uzman, sanki şirketin içindeymiş, hatta sistemin yöneticisiymiş gibi uzaktan bağlanıp kötü amaçlı işlemler yapabilir: verileri değiştirebilir, silebilir ya da kendine çıkar sağlayacak işlemler yapabilir. Dış uzmanın kendisine tanınan hakları kötü niyetle kullanarak yaptığı bu saldırılara **dış uzman** saldırısı denir.

12.2 Hukuki ve Etik Değerlendirme

Hukuki açıdan: Örneğin bir bankacılık sunucusu düşünün. Uzman, kendisine sağlanan ve sonra kaldırılması savsaklanan bir erişim hakkını kullanarak verileri değiştirir, siler ya da yarar sağlarsa suçludur. Erişim hakkını kaldırmayı savsaklayan taraf da hatalı davranmıştır.

Etik açıdan: Kurum uzmana neden erişim hakkı, neden yönetici yetkisi veriyor? Güncellemeleri ve değişiklikleri yapabilmesi için. Ayrıca uzman olduğu ve anlaşma kapsamında hizmet verdiği için ona güveniyor. Uzman bu yetkiyi amacı dışında kullanırsa meslek etiğine aykırı davranmış olur.

Biri "bana ne, unutmasalardı, elimde varsa istediğim gibi girer kullanırım" diyebilir. Hoca buna kesin bir hayır dedi. Bu yetki size yalnızca güncelleme için tanınmıştır. Güncelleme dışında yaptığınız bütün eylemler hem etik değildir hem de suçtur.

> **Hocanın vurgusu:** Dış uzmanlara ya da başka dış firma çalışanlarına verilen bütün haklar, iş biter bitmez iptal edilmelidir. Kurum yetkilileri bunu savsaklamamalıdır.

Hoca, yazılım güvenliğine dair bazı programların ve çerçevelerin erişim haklarının nasıl düzenlenip kaldırılacağını tanımladığını ve bunların uygulanmasını beklediğini söyledi.

> **Ders sonrası not:** Altyazıda bu çerçeve "COVID gibi programlar" diye geçiyor. Bağlamdan büyük olasılıkla BT yönetişim çerçevesi COBIT kastediliyor. Erişim yönetimi konusunda büyük olasılıkla ISO/IEC 27001 de benzer kurallar koyar.

13. İçeriden Saldırı 3: Sanal Saatli Bomba

13.1 Tanım

Hoca adı filmlerdeki saatli bombaya benzetti: Zamanı ayarlanır, geriye sayar ve sonunda patlar. Filmlerde kırmızı kabloyu mu mavi kabloyu mu keseceğiz sahnesi olur. Bizdekiler ise yazılımdır.

Bir yazılımın içine, bir tetik mekanizmasına bağlı olarak çalışan ve programı, programların çalışma şeklini ya da verileri bozan, silen, değiştiren bir program parçası eklenmesine **sanal saatli bomba** (logic bomb) denir.

13.2 Bankadaki Yazılımcı Örneği

Hoca Türkiye'de bir bankada yaşanan bir olayı anlattı. Bir çalışan yazılımın belli bir alanında kilit bir pozisyona gelmişti ve "banka beni işten atarsa" diye endişeleniyordu. Yazdığı kodun içine, kendisi işten ayrıldığında, örneğin sisteme giriş yapmadığında çalışacak bir sanal saatli bomba ekledi.

Gerçekten de işten atıldı. Atıldıktan sonra bomba çalıştı, yazılımı bozdu ve banka hizmet veremez hale geldi. Ama yazılımcı kodu açık açık bırakmamıştı. Bomba çalışıp bozma işini bitirdikten sonra kendini de siliyordu. Hoca bunu eski *A Takımı* dizisindeki "Bu mesaj 10 saniye içinde kendini imha edecektir" sahnesine benzetti. Böylece ortada hiçbir delil kalmadı.

Hukuki açıdan: Yazılımcı bir bomba programı hazırlamış ve bankanın bilgi sistemine bilinçli ve planlı şekilde zarar vermek için yerleştirmiştir. "Beni işten atarlarsa onlar da zarar görsün" diye özellikle yazdığı için suçludur. Ayrıca, dış uzman örneğindeki gibi, kimlik doğrulama (authentication) ve yetkilendirme (authorization) mekanizmalarıyla kendisine tanınmış yetkileri kullanarak kötü niyetli yazılımı yerleştirmiştir. Hoca bunu "çarpı iki", yani iki kat suç diye nitelendirdi. Bu yüzden cezası normalden daha ağır olur.

Ancak Türkiye'deki olayda bomba program kendini sildiği için varlığı saptanamadı ve ispatlanamadı. Yazılımcı da "ben yapmadım" dedi. Delil olmadığı için işten çıkarılan programcı suçlu bulunamadı. Banka bir şey yapamadı, ama bu olaydan ders çıkardı.

Etik açıdan: Bir kuruluşta çalışıyorsanız ve görevinizin gereği sistemin kritik yerlerine erişiminiz varsa, "bana bir şey olursa, ben gidersem burası da yansın" diye kuruluşa zarar verecek davranışlarda bulunamazsınız. Bomba türü programları yazmaya ve sisteme gömmeye hakkınız yoktur. Size verilen yetkiyi amacı dışında kullanmak işi ayrıca ağırlaştırır. "Mutsuz bir çalışanım, işten ayrılırken zarar vereyim" demek etik bir davranış değildir.

> **Hocanın vurgusu:** Verilen yetkiyi amacı dışında kullanmak suçu ağırlaştırır.

13.3 Yazılım Firması Örneği

Hocanın ikinci örneği muhasebe yazılımı gibi paket program satan bir yazılım şirketiydi. Bazı şirketler, lisans bedeli ödenmezse yazılımları müşteride kullanılamasın diye, lisans ya da bakım anlaşması dolduğu anda yazılımı işlevsiz hale getiren, çalışmasını bozan ya da veritabanını silen bir bomba programı ekleyebiliyor. Hoca böyle örneklerin olduğunu ve bunların doğrudan davalık olduğunu söyledi.

Müşteri bir lisans bedeli ödemiş ve yazılımı almıştır. Sonra memnun kalmadığı için lisansı yenilemek istemeyebilir. Şirket "madem öyle, programı kilitlerim, verilerine eriştirmem, sildim" derse, lisans anlaşmasının devam etmesi için bir tehdit unsuru işin içine girer.

Hukuki açıdan: Lisans ya da bakım anlaşmasının süresi dolduğunda yazılımı veya verileri bozacak bir kodu yazılımın içine gömerek satmak suçtur. Hoca verileri bozmanın daha da kötü olduğunu ekledi.

Olması gereken şudur: Müşteri, lisansa sahip olduğu dönemde parasını ödeyip aldığı yazılımı kullanmaya devam edebilir. Siz ona "artık kullanamazsın" diyemezsiniz. Ama şunu diyebilirsiniz:

- Yazılımın yalnızca bu halini kullanırsın.
- Hiçbir destek alamazsın, bozulursa başının çaresine bakarsın.
- Hiçbir güncelleme ve yama alamazsın, bakım yapılmaz.

Hocaya göre müşteri büyük olasılıkla yakın bir gelecekte değişen ihtiyaçlarla birlikte o yazılımı kullanamayacak ya da değiştirmek zorunda kalacaktır. Ama yazılımın satıcısı olarak programı ya da verileri silemezsiniz. Hem yazılımı hem veriyi o andaki haliyle bırakmanız gerekir.

> **Hocanın vurgusu:** Lisans süresi biten yazılımı kilitleyemezsiniz, verileri silemezsiniz. Destek ve güncellemeyi kesebilirsiniz.

13.4 Süreli Hizmetler ile Fark

Hoca burada bir itirazı ele aldı: Bulut sağlayıcıdan aylık ücretle 1 TB disk alanı aldım ve ödemeyi kestim. Madem verilere erişimi kısıtlayamıyor, ben ödemeden kullanmaya devam edeyim

mi? Hoca böyle bir şeyin söz konusu olmadığını söyledi (bkz. Örnek Sorular). Bu bir süreli kullanım lisansıdır ve lisansın içeriğini iyi okumak gerekir.

Bu tür hizmetlerde genellikle bir ek süre (grace period) tanınır, örneğin 3 ay. Bu sürede yeni yükleme yapamazsınız ve verileri değiştiremezsiniz, ama verilerinize erişip indirebilir, başka yere taşıyabilirsiniz. Süre 3 ay, 6 ay ya da 1 yıl olabilir ve sağlayıcı sizi sürekli "şu kadar zamanın kaldı" diye uyarır. Süre sonunda verileri almadıysanız sağlayıcı onları silebilir ve alanı başkasına açabilir. Bu bir saatli bomba değildir.

Hoca, yazılım lisansı satmanın da bir ticaret olduğunu ve ticaretin kendine özgü etik kuralları bulunduğunu söyledi. Yazılım üretiyor ve satıyorsanız bu kurallara uymalısınız. "Yarın öbür gün bir şey olur, kendimi korumaya alayım" diye yazılımınıza saatli bomba yerleştirme hakkınız yoktur.

14. İçeriden Saldırı 4: Bilgi Hırsızlığı

14.1 Tanım

Bilgi hırsızlığı, bir kuruma ya da kuruluşa ait önemli veya gizli verinin, yetki dahilinde erişilip görülebildiği halde, amacı dışında ve etik değerlerin dışında başka yerlere kaçırılması ya da satılmasıdır. Amaç büyük olasılıkla ticari çıkar elde etmektir.

14.2 Üç Örnek

Banka portföy yöneticisi: Bankacılıkta çok sık rastlanır. A bankasında bir portföy yöneticisi ya da şube müdürü var. Elinde bir müşteri portföyü var: Bu müşterilerin finansal verilerini görebiliyor, ne kadar zengin olduklarını, ne kadar işlem yaptıklarını ve bankaya ne kadar kazandırdıklarını biliyor. B bankasından bir teklif alıyor. Hoca bunu futbolcu transferine benzetti: Yönetici bir bedel karşılığında iş değiştiriyor ve eski bankasına ait müşteri bilgilerini yeni bankaya aktarıyor. Yani portföyüyle birlikte hareket ediyor.

Milli piyade tüfeği: Basına yansıyan bir haber. Bir milli kurum bir milli piyade tüfeği üretti. Bir yönetici bu tüfeğin bütün teknik bilgilerini rakip bir firmaya sattı.

MERNİS sızıntıları: MERNİS (Merkezi Nüfus İdaresi Sistemi), nüfus ve vatandaşlık işlerinin veritabanıdır. Hoca, vatandaşlık bilgilerinin pek çok web sitesinde yayınlandığının bilindiğini, bunun farklı sürümlerinin bile olduğunu ve yakın zamanda bir sızıntı daha olduğunun söylendiğini anlattı.

14.3 Hukuki ve Etik Değerlendirme

Banka yöneticisi: Bankada çalışan bir yöneticinin bankanın etik kurallarını bilmesi gerekir ve müşteri bilgilerinin gizli kalması bu kurallardan biridir. Müşteri bilgilerini başka yere aktarmak etik değildir. Ama bu davranışı hukuken kanıtlamak çok zordur. Müşterilerin hepsi "o yöneticiyle çalışmayı sevdiğim için oraya geçtim, sizin bankanızın benim için önemi yok" diyebilir. Hoca bunun hukuken yanlış bir davranış olduğunu, ama suçlu bulunma olasılığının çok düşük olduğunu söyledi.

Tüfek bilgilerini satan yönetici: Üst düzey yöneticinin bu bilgi transferi kesinlikle kabul edilemez. Hem kuruluşun etiğine hem de ulusal değerlere aykırıdır. Hukuken de suçtur. Ulusal güvenlik sırlarını sattığı için çok ağır şekilde cezalandırılması gerekir.

MERNİS: Verilerin sızmasına yol açan özensiz kamu görevlileri, kimse onlar, etik kuralları çiğnemiştir. Bilgilerin ortalığa saçılması ve deep web, dark web gibi ortamlarda bulunması kabul edilemez. Ama sızıntının nasıl olduğu kesin olarak belirlenmedi ya da belirlendiyse bile kamuoyu bilmiyor. Bilinçli mi yapıldı, bir hata sonucu mu oldu, net değil. Bu yüzden hukuken kesin bir hüküm kurmak da mümkün olmadı.

Hoca, ortada dolaşan teorileri "söylenti" olarak aktardı:

- Bir rivayete göre ilk sızıntılar seçim zamanında, seçmen listelerinin seçim sistemi ile MERNİS arasında aktarılması sırasında, aktarımın dinlenmesi ya da kopyalanmasıyla oldu.
- En güncel sızıntılarda ise bilgilerin e-Nabız'daki bir açık üzerinden toplandığı söyleniyor.

Hoca bunları kendisinin ispatlamadığını ve doğru olup olmadığını bilmediğini vurguladı. Net olarak ispatlanırsa hukuken gereğinin yapılması gerektiğini söyledi.

15. Dışarıdan Saldırılar: Bilgi Çalma, Değiştirme ve Silme

Hoca dışarıdan yapılan dört saldırı türü saydı: bilgi çalma, bilgi değiştirme, bilgi silme ve bir sistemin çalışmasını aksatma ya da durdurma. İlk üçü birlikte ele alındı.

15.1 Hedef Alınan Bilgiler

Bu saldırılarda bir bilgi sistemine erişim hakkı olmadan girilir ve bilgiler çalınır, değiştirilir ya da silinir. Hedef bilgi her şey olabilir:

- Ticari sırlar ve ticari bilgiler
- Mali bilgiler
- Özlük bilgileri ve kişisel bilgiler
- Sağlık bilgileri
- Ulusal güvenlik bilgileri (tüfek örneğinde olduğu gibi)

15.2 “Güvenlik Açığını Test Ediyordum” Savunması

Hoca yetkisiz girişi fiziksel dünyadaki izinsiz girişe benzetti. Bir evin kapısı ve kapıda kilit var, yani güvenlik önlemi alınmış. Siz yetkiniz olmadığı halde girmeye çalışıyorsunuz: anahtar uyduruyorsunuz ya da yandaki demirsiz pencereye tornavida sokup arkada kilit olup olmadığına bakıyorsunuz. Kilit yoksa içeri giriyorsunuz. Bu hırsızlık suçuna girer, çünkü erişim hakkınız olmayan bir yere zorla giriyorsunuz.

Savunmanızda “Hakim Bey, ben hırsızlık amacıyla girmedim, bu konutta güvenlik açığı var mı onu araştırdım” demeniz sizi suçsuz yapmaz ve suçunuzu hafifletmez. Bal gibi de pencereyi zorlayarak ya da anahtar uydurarak girdiniz.

Bilişim sisteminde de birebir aynı şey geçerlidir. “Bu sistem yeterince güvenli mi diye test ediyordum, bak şu arka kapıdan (backdoor) girdim, şu porttan yürüdüm” diyemezsiniz. Bu da yetkisiz giriştir ve suçunuzu hafifletmez. Girdikten sonra bilgileri çalmak, değiştirmek ya da silmek de aynı şekilde suçtur.

> **Hocanın vurgusu:** “Güvenlik açığını test ediyordum” bir savunma değildir. İzinsiz bir sisteme girmek amaç ne olursa olsun suçtur.

Hoca bu eylemlerin tamamının Türk Ceza Kanunu’nda suç olarak tanımlandığını ve yasaların 7. haftada ayrıca tartışılacağını söyledi. Etik açıdan bunların tartışmaya bile gerek olmadan yanlış olduğunu ekledi.

> **Ek bilgi (derste anlatılmadı):** Bilişim alanındaki suçlar büyük olasılıkla 5237 sayılı Türk Ceza Kanunu’nun “Bilişim Alanında Suçlar” bölümünde düzenlenmiştir. Büyük olasılıkla md. 243 bilişim sistemine izinsiz girmeyi, md. 244 sistemi engellemeyi, bozmayı ve verileri yok etmeyi veya değiştirmeyi, md. 245 banka ve kredi kartlarının kötüye kullanılmasını kapsar. Ayrıntılar dersin 7. haftasında işlenecek.

15.3 Silme ile Değiştirme Arasındaki Fark

Veriyi silmek nispeten kolay fark edilir. Veriler yok olmuştur ve en kötü ihtimalle bir yedekten (backup) geri dönersiniz. Belki son bir günü kaybedersiniz. Kayıp da kayıptır, ama en azından silme fark edilir.

Kötü niyetli biri verileri silmeden değiştiriyorsa bunu anlamak çok daha zordur. Hocanın örneği öğrenci bilgi sistemiydi. Biri sisteme girip bir notu değiştirdi diyelim. Kim, ne zaman fark edecek? Not yukarı doğru değiştiyse öğrenci “ne güzel olmuş” der ve hayatına devam eder. Aşağı doğru değiştiyse belki bir gün transkript aldığında “bu dersten A ile geçmemiş miydim, neden CB yazıyor?” diye fark eder, şikayet eder ve biri değişikliği bulur. Finansal ve ticari işlemlerde de bir şey değiştirilirse neyin değiştiğini fark etmek gerçekten zordur.

> **Hocanın vurgusu:** Veri değiştirme, veri silmekten daha tehlikelidir.

15.4 Çözüm: Log Kayıtları

Çözüm loglama mekanizmasıdır. Değişiklik dahil yapılan bütün eylemlerin hangi kullanıcı tarafından, ne zaman, hangi adresten ve ne tür erişimle yapıldığı olay kayıtlarında (log) düzgün şekilde tutulmalıdır.

Bu kayıtlar sistemin içinde değil, yanında, dışında tutulmalıdır. Aksi halde saldırgan "bu sistemde log da tutuluyordur" diyerek o tabloyu da silebilir ya da kendi işlemleri görünmesin diye güncelleyebilir.

16. Sistemin Çalışmasını Engelleme

16.1 DDoS

Dördüncü dış saldırı türü, sistemi meşgul ederek normal kullanıcılara verdiği hizmeti aksatmaktır. Bu genellikle zombileştirilmiş bilgisayarlarla, yani robot bilgisayarlarla yapılan dağıtık hizmet engelleme (Distributed Denial of Service, DDoS) saldırısıyla gerçekleştirilir.

16.2 Türkiye-Rusya Krizi Örneği

Hoca, Türkiye ile Rusya arasında bir kriz yaşandığını hatırlattı: önce bir Rus uçağının Suriye sınırında düşürülmesi, sonra Rus büyükelçinin vurulması. Bu dönemde Rus hacker grupları dünya genelinde başlattıkları bir DDoS saldırısıyla .tr uzantılı sitelere erişimi engelledi. Hoca bunun ülkeler arasında bile yapılabilen bir saldırı olduğunu ve bütün .tr uzantılı web sitelerinde çok ciddi sıkıntı yaşandığını söyledi.

> **Ders sonrası not:** Hoca saldırının 2016'da olduğunu söyledi, bir yerde de "2006" dedi (sürçme). Saldırı büyük olasılıkla Aralık 2015'te oldu ve .tr kök isim sunucularını hedef aldı. Bu tarih büyük olasılıkla uçağın düşürülmesinden (Kasım 2015) sonra, büyükelçinin öldürülmesinden (Aralık 2016) öncedir. Saldırının Rus hacker'lara ait olduğu bir iddiadır. Büyük olasılıkla saldırıyı Anonymous grubu üstlendi.

16.3 Hukuki ve Etik Değerlendirme

Yasalarımızda bir sistemin çalışmasını engellemek, aksatmak ya da durdurmak suç olarak tanımlanmıştır. Asıl sorun suçu kimin işlediğini tespit etmektir. Saldırı çok sayıda zombi bilgisayarla yapılır ve bu bilgisayarlar istekleri başlatıp kapatmadan sistemi meşgul eder. Bu eylemin yöneticisini saptamak kolay değildir. Saptasanız bile hocaya göre yüzde 99,9 ülke dışında olduğu için yakalamak zordur. Saldırganlar başka bir ülke tarafından destekleniyorsa yapabileceğiniz pek bir şey kalmaz. Bu tür olayları genellikle Anonymous gibi gruplar ya da bir ülkenin istihbarat kuruluşu gerçekleştirebilir.

16.4 Stuxnet

Hoca bir başka örnek olarak Stuxnet saldırısını hatırlattı. İran'ın nükleer programına zarar vermek için, internet bağlantısı olmayan ve nükleer çalışmaları yöneten bilgisayarlara bir virüs bulaştırıldı. İnternet olmadığı için virüs USB bellek üzerinden bulaştırıldı. Hoca bunun bir kullanıcının zaafı üzerinden, örneğin "şu videoyu da izleyeyim" demesiyle olmuş olabileceğini söyledi. Kapalı ağa yerleştirilen virüs İran'ın nükleer programının ciddi zarar görmesine yol açtı.

> **Ders sonrası not:** Stuxnet büyük olasılıkla 2010'da ortaya çıktı ve Natanz tesisindeki santrifüjleri hedef aldı. USB bellekle bulaştığı genel kabul görür. Hocanın "şu videoyu izleyeyim" ifadesi bir varsayımdır, bilinen bir ayrıntı değildir.

Etik açıdan, rakip bir firmanın ya da düşman görülen bir ülkenin sistemlerini meşgul edip hizmet veremez hale getirmek etik değerlerle bağdaşan bir davranış değildir.

17. İnternet Bankacılığı Soygunları ve Sosyal Mühendislik

Hoca, içeriden ve dışarıdan diye sınıflandırmadığı, ama çok yaygın olan internet bankacılığı soygunlarını ayrıca anlattı. Bu bölümde güvenlik önlemleri ile saldırı yöntemlerinin birbirini

nasıl izlediği görülüyor.

17.1 Tuş Kaydediciler

En eski yöntem, tuş kaydedici (keylogger) yazılımlarla müşterinin kullanıcı numarasını ve parolasını kaydetmektir. Bu bilgileri banka sunucusuna girerek elde etmek çok zordur. İstemci ile sunucu arasındaki iletişim de şifrelidir, bu yüzden hattı dinleyerek de elde edilemez. Ama müşterinin bilgisayarına bir casus program kurulursa bilgiler rahatlıkla alınabilir.

Hoca Türkiye'de yaşanan ilk olaylardan birini anlattı. Bir müşteri internet bankacılığı hesabına girildiğini söyleyerek şikayet etti. Banka inceleme yaptı ve "sizin kullanıcı adınız ve şifrenizle şuradan girilmiş, bizim güvenliğimizde eksik yok, şifrenizi çaldırmışsınız" dedi. Müşteri o yerde yaşamadığını söyledi. Dava uzun sürdü. Bilirkişi incelemesinde, müşterinin torunlarının oyun oynamak için girdikleri sitelerden bilgisayara keylogger bulaştığı ortaya çıktı. Müşteri bankacılık işlemi yaparken bilgileri kaydedildi ve hesabı boşaltıldı.

Mahkeme bankayı da kusurlu buldu. Gerekçe şuydu: Kullanıcı bunu bilerek ve isteyerek yapmamıştır. Banka, müşterinin hiç girmediği bir yerden giriş yapılmasına neden izin vermiştir?

17.2 Sanal Klavye ve Ekran Kaydediciler

Bunun üzerine sanal klavye geliştirildi. Şifre klavyeden girilemiyor, sayıları sürekli yer değiştiren bir ekran klavyesinde fareyle tıklanarak ya da fare üzerinde bekletilerek giriliyordu. Böylece keylogger etkisiz hale getirildi.

Ama bu kez fare hareketlerini izleyen ve ekran görüntüsü alıp bir yerlere gönderen kötü amaçlı yazılımlar ortaya çıktı. Tıklanan yerler ve üzerlerindeki sayılar ekranda göründüğü için şifre yine çalınabildi. Yine hesap boşaltmaları ve davalar yaşandı, bankalar yine eksik bulundu. Hoca bu davaların yıllar sürdüğünü ve müşteki olarak ne kadar yıpranabileceğinizi düşünmemizi istedi.

17.3 İki Faktörlü Doğrulama

Ardından iki faktörlü doğrulama (two-factor authentication, 2FA) ortaya çıktı. Kullanıcı adı ve şifre girildikten sonra banka sizi doğrudan içeri almaz. Bir şifreleme cihazından ya da sistemde tanımlı telefonunuza gönderilen tek kullanımlık parolayı (one-time password, OTP) da girmenizi ister. Bu da doğruysa sizin siz olduğunuzu kabul eder. Hoca bu yöntemin bugün hâlâ standart olarak kullanıldığını, ama yüzde yüz güvenli olduğunu söylemenin doğru olmadığını belirtti.

17.4 Güncel Sosyal Mühendislik Yöntemi

Bankalar sürekli "biz sizden asla şifrenizi istemeyiz, şifrenizi kimseye söylemeyin" diye uyarır. Hoca, kötü niyetli kişilerin bunu nasıl aştığını adım adım anlattı:

- **Arama:** Dolandırıcı, bankanın resmi numarasına çok benzeyen, örneğin yalnızca alan kodu farklı bir numaradan arar. Çağrı merkezlerindeki kalıp konuşmaları kullanır: "Bilmem kimle mi görüşüyorum? Görüşmelerimiz kayıt altındadır."
- **Yem:** "Yaptığımız incelemede kredi kartınızdan geçmişte aidat alındığı görüldü, yasa gereği iade edilmesi gerekiyor. Onaylıyorsanız işlem yapacağız" der. Örneğin 10 bin lira iade edileceğini söyler. Kurban para geleceği için onaylar.
- **Giriş:** Dolandırıcı kurbanın kimlik numarasını, adını ve soyadını zaten internetten bulmuştur. Kurban telefondayken onun adına internet bankacılığına giriş yapmaya başlar.
- **Şifreyi alma:** "Bankamızın güvenlik politikası gereği şifrenizi asla sormuyoruz. Ama doğrulama için sizi sesli yanıt sistemine aktaracağım, lütfen şifrenizi tuşlayın" der. Arkadan bir sesli yanıt sistemi sesi çalınır. Kurban, kimliğinin doğrulandığını sanarak şifresini telefona tuşlar. Her tuşun bir tonu vardır. Dolandırıcı altı haneli şifreyi bu tonlardan yakalar ve ekranına yazar.
- **İkinci faktörü aşma:** "Teşekkür ederim, doğrulamadan geçtiniz, işleminizi başlatıyorum. Telefonunuza bir mobil onay kodu gelecek, onu girmemiz gerekiyor" der. Kurban kodu söyler, bir yere girer ya da bazı bankalarda gelen anlık bildirime (push notification) onay

verir. Böylece dolandırıcı iki faktörlü doğrulamayı da kurbana yaptırmış ve onun yerine giriş yapmış olur.
- **İzlenim yaratma:** Dolandırıcı kurbanın kredi kartından nakit avans çekip 10 bin lirayı onun hesabına yatırır. Bankadan "hesabınıza 10 bin TL geldi" mesajı gelir ve kurban iadenin geldiğini sanar.
- **Soygun:** Bu arada yapabildiği bütün havaleleri yapar. Müşteri yeterince safsa "başka bir kartınızın da aidatı varmış", "bir sigortanızın bonusu varmış" diyerek yeni onay kodları ürettirir, kurbana bunları onaylatarak kredi çeker ve para transfer eder.

  Ek bilgi (derste anlatılmadı): Telefon tuşlarına basıldığında çıkan seslere DTMF (Dual-Tone Multi-Frequency) tonları denir. Her tuş, biri düşük biri yüksek frekans grubundan iki sinüs dalgasının toplamıyla kodlanır. Bu yüzden ses kaydından hangi tuşlara basıldığı kolayca çözülebilir. Hocanın anlattığı şifrenin tuş seslerinden yakalanması bu özelliğe dayanır.

  Hocanın vurgusu: İki faktörlü doğrulamaya da tek başına güvenmeyin. İnternet şifrenizi ve mobil onay kodlarınızı hiçbir yere girmeyin, kimseye söylemeyin.

Gerçek banka bazen gerçekten arar ve bir güvenlik doğrulaması ister. Ama internet şifrenizi asla sormaz. En fazla kredi kartı şifrenizin örneğin birinci ve dördüncü hanesini sorabilir, tamamını sormaz. "Sesli yanıt sistemine girin" gibi yönlendirmelere kanmamak gerekir.

Hoca bu yöntemlerde çok fazla sosyal mühendislik yapıldığını söyledi. Hiçbiri etik ya da ahlaklı değildir. Toplumun tamamı ahlak kurallarını bilse de bu kişiler bilerek kurala uymamayı seçiyor. Hocaya göre etik değerlerin yaptırımı yalnızca meslek etiğinde, odalar üzerinden biraz vardır. Bunun dışında iş yasal cezaya varmadıkça ne etiği ne ahlakı kimse önemsiyor.

18. Bilişim Yoluyla da İşlenen Suçlar

Hoca AB uyumlu yasalardaki sınıflandırmaya döndü. İlk grup, daha önce de bilinen ve işlenen, ama artık bilişim ağları kullanılarak da işlenen suçlardır.

18.1 İntihara Yönlendirme

Ruhsal desteğe ihtiyacı olan kişileri, özellikle çocukları, oyunlar ve topluluklar üzerinden intihara yüreklendiren, cesaret veren, hatta kışkırtan kişiler ve gruplar vardır. Bu kişiler tek başlarına ya da grup halinde çalışarak seçtikleri bir kurbanı tehditlerle intihara sürükleyebiliyor. Hoca, ders tarihinden birkaç hafta önce yaşanan ve Discord'a erişim engeli getirilmesine yol açan olayları örnek verdi.

Hocaya burada "birini intihar ettirince ne geçiyor eline?" diye soruldu (bkz. Örnek Sorular). Hocanın cevabı bunun bir tür tatmin olduğuydu: "Bak gördün mü, dediğimi yaptırdım. Sosyal mühendisliğin son noktasındayım. İstersem bir kişinin canını almasını bile sağlayabiliyorum."

18.2 Uyuşturucu ve Sağlık İçin Tehlikeli Madde

İntihara yönlendirmeye benzer şekilde gruplar ve topluluklar uyuşturucu ve uyarıcı madde kullanımını kolaylaştırabiliyor, hatta ticaretini yapabiliyor. Uyuşturucu e-ticaret yoluyla pazarlanabiliyor ve bu konuda önlem alınması gerekiyor.

Benzer bir suç, sağlık için tehlikeli madde temin etmektir, örneğin reçeteli ilaç satışı. Hocaya göre bu şekilde satılanların büyük olasılıkla hepsi sahtedir. Yatıştırıcı ya da uyutucu bir ilaç aldığınızı sanırken büyük olasılıkla tebeşir tozu alıyorsunuz.

18.3 Kumar

Kumar bazı ülkelerde yasak, bazılarında serbest ya da düzenlemelere tabidir. Kumarın yasak olduğu bir ülkede bunu yüzde yüz engelleyemezsiniz. İnsanlar internet üzerinden kumar oynamaya çalışır. Kumar oynatanlar ülke içinde değil, kumarın serbest olduğu bir ülkede bulunur ve işi oradan yönetir. Kumarı yasaklayan ülke ancak para trafiğini önleyecek çalışmalar yapabilir. Hoca, son dönemde banka hesabı kiralama nedeniyle çok fazla ceza verilmeye başlandığını hatırlattı.

18.4 Müstehcenlik ve Fuhuş

Müstehcenlik toplumdan topluma değişir. Her ülke kendi geleneğine, göreneğine ve ahlak anlayışına göre bunu tanımlar ve suç olarak kabul eder ya da etmez.

İnternetin bilgi paylaşımını ve duyuruyu kolaylaştırması, bilişim sistemlerini fuhuş için de bir ortam haline getirdi. Eylemin karşılıklı rızayla mı yoksa para karşılığı mı gerçekleştiğini anlamak kolay değildir. Ülkeler burada da kendi anlayışlarına göre farklı değerlendirir: Kimisi serbest bırakır, kimisi çok ağır cezalar verir.

18.5 Çocukların Cinsel İstismarı

Hocaya göre çocukların cinsel istismarı, tüm dünyanın üzerinde görüş birliğine vardığı tek konudur. Müstehcenlik tartışılabilir, ama bu kesinlikle tartışılmaz. Burada da bir sorun vardır: çocuğun tanımı. Yaş mı önemlidir, vücut gelişmişliği mi? Bu konuda uzlaşı yoktur ve ülkeler farklı değerlendirir. Türkiye'de çocuk istismarına yönelik görselleri üretmek, dağıtmak, hatta bilgisayarda bulundurmak doğrudan suçtur ve çok ciddi cezaları vardır.

19. Özel Hayata Karşı Suçlar ve Kişisel Veri

19.1 Özel Hayatın Gizliliği

AB uyumlu yasalardaki ikinci grup özel hayata karşı işlenen suçlardır. Bir kişinin özel hayatına dair bilgilerin öğrenilmesi ve ifşa edilmesi, yani halka açılması ve yayılması, genel ahlaka tamamen aykırıdır. Bu konu Birleşmiş Milletler İnsan Hakları Evrensel Beyannamesi'nde doğrudan ele alınmıştır ve özel hayatın gizliliği ilkesi Türkiye Cumhuriyeti Anayasası'nda da yer alır.

Bu çerçevede herkesin haberleşme özgürlüğü vardır. Haberleşmelerin dinlenmesi, kaydedilmesi ve kayıtların yayınlanması yasaktır. Yalnızca gerekli görüldüğünde, hakim kararıyla, yani yargı kararıyla dinleme ve kayıt yapılabilir. Bir kişinin özel yaşantısına dair bilgiler de kamuya açık hale getirilemez, yayınlanamaz. Bu da yasalarla koruma altındadır.

19.2 Kamuya Mal Olmuş Kişiler

Toplumun yakından izlediği, yaşantısı basında yer alan kişiler için bu yasalar biraz daha esnek yorumlanır. Hocanın örnekleri politikacılar ve sanatçılardı. Sanatçı yapısı gereği göz önündedir, konserlere çıkar. Gece bir yerde eğlenip muhabirlere küfrederse ya da biriyle görüntülenirse bunun magazin haberi olması, kişi tanınan biri olduğu için daha esnek değerlendirilir. Politikacılara yapılan sert eleştiriler de "sen politikacısın, bunu karşılayabilmelisin" anlayışıyla daha esnek yorumlanır.

19.3 Verilerin Birleştirilmesi

Bugün veriler ayrı ayrı bilişim ortamlarında tutuluyor. Ama bu veriler bir araya geldiğinde çok önemli bilgiler ortaya çıkabilir ve bu bilgiler kişinin hayatını ve geleceğini bile etkileyebilir. Bu yüzden kişisel verilerin çok iyi izlenmesi gerekir.

19.4 Kişisel Veri

Hocanın tanımıyla kişisel veri, kişiye ait her türlü bilgidir. Hocanın saydığı örnekler:

- Kimlik bilgileri
- Irk ve etnik köken
- Siyasi düşünce ve felsefi inanç
- Din, mezhep ve diğer inançlar
- Kılık ve kıyafet
- Dernek, vakıf ve sendika üyelikleri
- Sağlık bilgileri
- Cinsel hayat
- Ceza mahkumiyetleri ve güvenlik tedbirleri

- Biyometrik veriler: retina, parmak izi gibi biyometrik tanımlayıcılar

Bu verilerin açığa çıkmaması gerekir ve anayasayla koruma altındadır. Hoca ne kadar korunduğumuzu bilemediğimizi, ama bunları ifşa etmenin hem etik hem ahlak dışı hem de yasal olarak suç olduğunu söyledi.

> **Ek bilgi (derste anlatılmadı):** Türkiye'de kişisel veriler büyük olasılıkla 2016'da yürürlüğe giren 6698 sayılı Kişisel Verilerin Korunması Kanunu (KVKK) ile korunur. Hocanın saydığı ırk, etnik köken, siyasi düşünce, din, sağlık, cinsel hayat, ceza mahkumiyeti ve biyometrik veri gibi örnekler, büyük olasılıkla bu kanunun 6. maddesinde "özel nitelikli kişisel veri" olarak ayrıca sayılır ve daha sıkı koşullarla işlenebilir.

20. Mal Varlığına Karşı Suçlar

Hoca başlıkların sırasını karıştırmış olabileceğini söyleyerek bir sonraki grup olan mal varlığına karşı suçlara geçti. Bunlar maddi karşılığı olan suçlardır.

Bir kişinin parasını ya da malını bilişim sistemi kullanarak çalmak nitelikli hırsızlık sayılır. Bütün internet bankacılığı soygunları ve kredi kartıyla yapılan kötü niyetli işlemler nitelikli hırsızlık ve dolandırıcılık kapsamında değerlendirilir ve cezaları buna göre verilir.

Finansal işlemlerin internet üzerinden yapılması giderek yaygınlaşıyor. Hoca, eskiden banka şubesine gidip sıra beklemesi ve evrak vermesi gerekirken artık telefonundan iki dakikada işini hallettiğini söyledi. Bu bankaların da işine geliyor, çünkü şube masrafı yerine internet üzerinden giderlerini büyük ölçüde azaltabiliyorlar. Bu yüzden bu suçlar da daha önemli hale geliyor.

Bu gruptaki örnekler:

- **Kayıp ve çalıntı kartlar:** Unutulmuş ya da çalınmış kartlarla yapılan işlemler çok yaygındır. Bizi ilgilendiren taraf, kredi kartı işlemlerinin bilişim sistemleri üzerinden geçmesidir.
- **Manyetik şeritli kartların kopyalanması:** Manyetik şerit okutulur, aynı bilgiler başka bir karta yazılır ve artık yalnızca bu şeritteki verilerle işlem yapılabilir. Şifre korumalı çipli (smart) kartlarda bu yapılamaz. Bugün şifresiz işlem yapılamadığı için bu suç azaldı. Belli bir limitin altındaki temassız işlemlerde şifre sorulmaz, ama orada da temassızın kendi şifreleme politikası devreye girer.

  > **Ders sonrası not:** Hoca manyetik şerit kopyalamaya "kimlik hırsızlığı" dedi. Doğru terim kart kopyalamadır (skimming, kart klonlama). Kimlik hırsızlığı (identity theft), başkasının kimlik bilgileriyle onun adına işlem yapmaktır ve daha geniş bir kavramdır.

Hocaya göre çeşitli yöntemlerle finansal suçlar hâlâ işlenebiliyor. Paraya bağlanan bütün bu suçlar yasalarda mal varlığına karşı suçlar olarak sınıflandırılır.

21. Kötü Amaçlı Yazılımlar, Fidye Yazılımı ve Kritik Altyapılar

21.1 Virüs

Hoca son olarak bu saldırıların nasıl yapıldığına geçti. Kullanıcıların bilerek ve isteyerek yaptıkları eylemler dışında saldırıların temelinde virüsler ya da kötü amaçlı yazılımlar vardır. Virüs aslında daha özel bir tanımdır, ama halk dilinde bütün kötü amaçlı yazılımlara virüs denir.

Virüs, bir bilgisayardaki programları ya da verileri bozmayı hedefleyen kötü amaçlı yazılımdır. Hem programın çalışmasını hem de veriyi ve veriye erişimi bozmayı amaçlar. İlk dönemlerde virüsler daha çok tanınırlık ("vay, adam virüs yazmış") ve kişisel tatmin için yazılıyordu. Sonra daha kötü amaçları olduğu ortaya çıktı.

Etik açıdan, virüs yazarak insanlara zarar vermek hem ayıptır hem ahlaki değildir ve etik değerleri hiçe saymaktır. Hukuki açıdan, verdikleri zarara göre virüs yazanlar ve dağıtanlar hakkında yasal işlem yapılır. Hoca Türkiye'de bunun hapis cezası verilen örnekleri olduğunu söyledi. Para sızdırmak için yazılan virüsler ise mali suçlarda olduğu gibi nitelikli dolandırıcılık olarak yargılanır.

21.2 Kötü Amaçlı Yazılım Türleri

Bu yazılımlar kötü amaçlı yazılım (malicious software, malware) olarak adlandırılır. Hoca türleri tek tek tartışmadı, bunların bilişim sistemleri güvenliği dersinden bilinebileceğini söyledi. Saydığı türler:

- Truva atı (trojan)
- Solucan (worm)
- Arka kapı (backdoor)
- Virüs

21.3 Fidye Yazılımı

Fidye yazılımı (ransomware), Türkçede kurtulmalık yazılımı ya da fidye yazılımı diye de geçer. Genellikle oltalama (phishing) saldırılarıyla yayılır. Bir e-posta ya da haber bağlantısı gibi görünür.

Hocanın örneği bir internet servis sağlayıcısını taklit eden bir kandırma e-postasıydı: "Son ödeme tarihi … Ekim olan Eylül 2024 dönemine ait 2746 TL tutarındaki ev interneti faturanız ektedir." Kullanıcı "2746 liralık internet faturası mı olur?" diye şaşırır ve PDF sandığı eke tıklar. Böylece bir betiğin ya da kötü amaçlı yazılımın çalışmasını tetikler.

Yazılım bilgisayara yüklenir, dosyaları ve diski şifreleyerek sıkıştırır. Sonra "verilerine erişmek istiyorsan şu cüzdana şu kadar bitcoin gönder, sana parolayı yollarız. Göndermezsen şifreli kalır" der. Hoca pek çok şirketin ve bireyin bu tür oltalama saldırılarına takıldığını ve çok ciddi paralar ödendiğini söyledi.

> **Hocanın vurgusu:** Yedekleme (backup), fidye yazılımına karşı en önemli korumadır.

21.4 Kritik Altyapılar

Bugün pek çok şehir ve yaşam sistemi bilgisayarlarla yönetiliyor: petrol boru hatları, su dağıtım sistemi, elektrik şebekesi, gaz dağıtım sistemi, trafik denetim sistemleri. Hatta bazıları akıllı hale getiriliyor. Örneğin kavşaktaki ışıklar araç sayısına göre ayarlanıyor ve araç fazla olan yöne daha uzun yeşil ışık yakılıyor.

Bir bilgisayar sistemi varsa bir ağ ortamı da var demektir. Sistem uzaktan yönetiliyorsa, yani uzaktan erişim varsa, yetkisiz erişim de her zaman mümkündür. Dolayısıyla derste farklı açılardan sınıflandırılan bütün saldırı biçimleri bu hayati sistemlere de yapılabilir ve yapılıyor. Bunların hiçbiri etik ya da ahlaka uygun değildir ve yasalarda cezaları tanımlanmıştır. Ama herkes ahlaklı davranmadığı ve etik kuralları çiğneyebildiği için bunları yaşamaya devam edeceğiz.

Hocanın kapanış yorumu şuydu: Etik bilinç bireyden başlayarak yerleşir ve yükselirse bu suçlar belki azalır, ama hiçbir zaman tamamen kaybolmaz.

Örnek Sorular

Soru 1 (derste sözlü, 00:57:16)

Bir bankada faiz hesabındaki yuvarlama farkları salam dilimi yöntemiyle özel bir hesaba aktarılıyor. Her işlemde ortalama yarım cent çalınıyor ve günde 1000 faiz işlemi yapılıyor. Günlük ve 30 günlük kazanç kaç dolardır?

Derste hoca önce "500 dolar mı, 50 dolar mı?" diye düşündü ve günde 50 dolar, 30 günde 1500 dolar dedi. Bu cevap hatalıdır.

> **Çözüm (derste verilmedi):** Günlük kazanç $1000 \times 0{,}5 = 500$ cent eder. 1 dolar 100 cent olduğu için bu $500/100 = 5$ dolardır. 30 günde $5 \times 30 = 150$ dolar eder. (Python ile doğrulandı.)

Soru 2 (derste sözlü, 01:13:52)

Bir bulut sağlayıcıdan aylık ücretle 1 TB disk alanı satın aldım ve ödemeyi kestim. Lisansı biten yazılımın kilitlenemediği gibi, sağlayıcı da verilerime erişimimi kısıtlayamaz mı? Ödemeden kullanmaya devam edebilir miyim?

Hocanın cevabı: Hayır. Bu bir süreli kullanım lisansıdır ve lisansın içeriği iyi okunmalıdır. Bu tür hizmetlerde genellikle örneğin 3 aylık bir ek süre (grace period) tanınır. Bu sürede yeni yükleme yapılamaz, veriler değiştirilemez, ama indirilip başka yere taşınabilir. Sağlayıcı sürekli uyarı gönderir. Süre sonunda veriler alınmadıysa silinebilir ve alan başkasına açılabilir. Bu, satılmış bir yazılıma gömülen saatli bombadan farklıdır ve etik dışı değildir.

Soru 3 (derste sözlü, 01:45:31)

Birini internet üzerinden intihara yönlendiren kişinin bundan ne kazancı vardır?

Hocanın cevabı: Bu bir tür tatmindir. Kişi “dediğimi yaptırdım, sosyal mühendisliğin son noktasındayım, istersem bir kişinin canını almasını bile sağlayabiliyorum” duygusunu yaşar.

Dersin Toparlaması

Derste önce ahlak, etik ve yasa kavramları birbirinden ayrıldı. Ahlak, toplumun çoğunluğunca kabul edilen, nedeni sorgulanmayan ve topluma göre değişen kurallar bütünüdür. Din, temel değerler, felsefe, kültür, etik ve yasalardan beslenir. Etik, ahlak ilkelerinin mantıksal ve sistematik düzenidir ve ders kaynağına göre evrenseldir. Yasa ise zorunlu ve yaptırımlıdır. Etik; bireysel etik, meslek odalarının tanımladığı meslek etiği, kurum ve kuruluşların topluma ve çalışanlarına karşı sorumluluklarını kapsayan kurumsal etik ve sistem yapma ile kullanma etiği olan bilişim etiği olarak ayrıştırıldı. Sadakat kartı verilerinin satılması, emisyon testi yazılımı ve kalıcılaşan deprem vergileri gibi örnekler, etik dışı davranışın yalnızca bireylere değil kurumlara da özgü olabildiğini gösterdi.

İkinci yarıda bilişim suçları teknik açıdan (etken ve edilgen, içeriden ve dışarıdan) ve AB uyumlu yasalar açısından (bilişim yoluyla da işlenen suçlar, özel hayata karşı suçlar, mal varlığına karşı suçlar, bilişim alanında suçlar) sınıflandırıldı. Salam dilimi, dış uzman, sanal saatli bomba, bilgi hırsızlığı, veri değiştirme, DDoS, internet bankacılığı dolandırıcılığı ve fidye yazılımı örnekleri hem hukuki hem etik açıdan değerlendirildi. Ortak dersler şunlardı: verilen yetkiyi amacı dışında kullanmak suçu ağırlaştırır, “güvenliği test ediyordum” bir savunma değildir, kod gözden geçirme, erişim haklarının zamanında kaldırılması, sistem dışında tutulan loglar ve yedekleme temel korumalardır. Sonraki derste fikir ve sanat eserleri üzerindeki haklar ile meslek etiği ve mühendislik etiği, özellikle bilgisayar mühendisliği etik kuralları işlenecek. Bilişimle ilgili yasalar ise 7. haftada ayrıntılı tartışılacak.

Not: İsterseniz bu kayıtları Gemini Notebook gibi bir araca atıp daha istifadeli hale getirebilirsiniz.